International Journal of Accounting Information Systems 51 (2023) 100642

Contents lists available at ScienceDirect

International Journal of Accounting Information Systems

journal homepage: www.elsevier.com/locate/accinf

# A pathway model to five lines of accountability in cybersecurity governance

Sergeja Slapničar *, Micheal Axelsen, Ivano Bongiovanni, David Stockdale

*University of Queensland, 4067 St Lucia, Australia*

ARTICLE INFO

*Keywords:*
Cyber risk management
Cybersecurity governance
Five lines of accountability
Institutional theory
Constrained-efficiency framework

ABSTRACT

In an in-depth field study, we investigate cyber security governance configurations vis-à-vis the five lines of accountability (5 LoA) – that is, the Three Lines Model extended by the accountability of executive management and the board of directors (IIA, 2020). The aim is to explore the configurations adopted by organizations in governing cybersecurity, and why it would matter for cyber security whether the five lines of accountability are adopted. We define the type of the 5 LoA adoption by: (i) the segregation of the lines that spans from blended to segregated and (ii) the level of engagement of those in line roles that ranges from low to high. In this way, we identify four types of adoption of the 5 LoA: 'no adoption, 'ostensible', 'implicit', and 'explicit' adoption. We theorize how the type of adoption of the 5 LoA is affected by the interplay of institutional forces and organizations' need for efficiency and effectiveness, and develop a pathway model for organizations' adoption of the 5 LoA. We find that organizations that adopt the 5 LoA with clear segregation between these lines ('ostensible' and 'explicit' adoption) are those subject to prudential regulation (coercive forces), whereas efficiency motives and mimetic forces drive organizations to seek fluidity and flexibility by 'blending' the segregated lines ('implicit' adoption) to ensure fast reactions to changing environment. Regardless of the segregation between lines and whether they are blended or not, we found that all organizations see scope to improve the level of engagement in the 5 LoA to improve the effectiveness of cyber security governance.

## 1. Introduction

Cyber security (CS) risks are among the most compelling business risks in the digital economy (World Economic Forum, 2023). Despite a steady increase in CS investment by public and private sector organizations (KPMG, 2019), cyber-crime is on the rise (Lee, 2021). Global phenomena such as the COVID-19 pandemic have exacerbated CS risks as employees increasingly work remotely using networks and devices outside the organization's control (Ali et al., 2020; Škiljić, 2020).

Notwithstanding that the common recognition of CS as a business problem rather than solely an information technology (IT) problem, CS governance has received scant research attention in comparison to the extensive research studying the technical side of CS. CS governance addresses how organizations delegate decision-making authority from their Board of Directors (BoD) to various operational and managerial levels to ensure the confidentiality, integrity, and availability of the organization's digital assets (Lyons, 2011; ISO/IEC 27014; 2013). CS governance has clear implications for CS risk management, which relates to information security risks

* Corresponding author.
*E-mail addresses:* s.slapnicar@uq.edu.au (S. Slapničar), m.axelsen@uq.edu.au (M. Axelsen), i.bongiovanni@uq.edu.au (I. Bongiovanni), d.stockdale@uq.edu.au (D. Stockdale).

https://doi.org/10.1016/j.accinf.2023.100642
Received 28 February 2022; Received in revised form 23 February 2023; Accepted 20 July 2023
Available online 7 August 2023
1467-0895/© 2023 The Authors. Published by Elsevier Inc. This is an open access article under the CC BY-NC-ND license (http://creativecommons.org/licenses/by-nc-nd/4.0/).

arising *"specifically from threats and vulnerabilities related to the connection to and use of cyberspace. It refers to the processes and controls implemented by an entity to manage CS risks"* (AICPA, 2017). In other words, CS governance is an overarching term for the BoD's strategic direction and oversight of cyber risk management and its operational implementation.

CS governance and risk management are greatly influenced by practitioner guidelines (Institute of Internal Auditors [IIA], 2016) rather than by insights from academic research. Professional organizations (Committee of Sponsoring Organizations of the Tredway Commission (COSO), 2004; 2013; 2017; IIA, 2013; 2016; 2020), financial regulators (the Basel Committee on Banking Supervision's Principles for Sound Management of Operational Risk, 2011; 2021), risk management associations (ISACA), and major consulting firms intensively promote the three lines of defense (3 LoD) model of risk management.

One criticism of the 3 LoD model is the focus on 'defense' and the tendency for risk management to become the 'Office of No', rather than helping management deal with uncertainty (Leech and Hanlon, 2016). A further criticism is that the 3 LoD does not expressly recognize the role of executive management and the BoD (Lyons, 2011; Leech and Hanlon, 2016). In fact, renowned lawsuits related to cyber incidents have been directed precisely at BoDs and executive managers, suggesting that stakeholders see them as the ultimately accountable bodies (Leech and Hanlon, 2016). The involvement of the BoD and executive management in cyber security has been advocated for at least two decades (NIST framework 2018; COBIT, 2019; Lyons, 2011; Protiviti, 2013).

In response, the IIA acknowledged additional layers in cyber risk management and governance and that to create value, an organization needs to accept and manage levels of risk. Consequently, the IIA omitted the term 'defense' and recognized the express roles of executive managers and boards in its updated Three Lines Model (TLM). While IIA (2020) continued to refer to the updated TLM, the model actually identifies five lines of accountability. These are the first, second, and third lines of the 3 LoD as well as the lines of management and the BoD. We refer to the updated TLM as the 5 LoA model to emphasize this difference.

In comparison to the traditional 3 LoD, the new model allows for a higher degree of flexibility in the design of lines, referring to their close cooperation and even integration, and emphasizes the responsibilities of the relevant governance actors (Eulerich, 2021). To the best of our knowledge, the 5 LoA model is the sole prescriptive professional framework that institutionalizes the governance configurations framing the relationships between the BoD, executive managers, and those in the organization that address cyber security risk management. Although the involvement at all levels across the organizational hierarchy is a common theme in similar national frameworks, the 5 LoA model represents the standard of best practice and an efficient approach to summarizing comprehensive organizational involvement suggested by professional organizations and academics. Given the regulatory vacuum on BoD's required degree of involvement in cyber security, guidelines by eminent organizations in this field are incredibly recent: the Australian Institute of Company Directors (AICD) and CS Cooperative Reseach Centre only in October 2022 published a set of guidelines to help directors on Australian boards oversee cyber risk management (AICD & CS Cooperative Research Centre, 2022).

Descriptive evidence suggests that organizations may not be aligned with the updated model: over 60% of organizations assign accountability for CS to the IT function (ACCA and CAANZ, 2019). Only about a third of large organizations consider cyber risk management a C-suite responsibility. Furthermore, 59% of organizations say that the relationship between CS and different areas of the organization is at best neutral, but more likely mistrustful or non-existent, and 60% of organizations do not have a CS specialist who would sit on the BoD or at the executive management level (EY and IIA, 2021).

While cyber-attacks continue to increase, the success of governing bodies in addressing cyber risks and security breaches is relatively unknown (Hartmann and Carmenate, 2021). There is no research evidence about which CS governance structures are adopted in practice, and how different lines collaborate and monitor each other[1].

In this research our aim is to explore the configurations adopted by organizations in governing cybersecurity, why it would matter for cyber security whether the five lines of accountability are adopted, and which factors affect their adoption. To address this aim, we draw on the constrained-efficiency framework (Roberts and Greenwood, 1997) that argues that organizations balance efficiency and institutional pressures in their decisions to adopt a certain governance model. This framework integrates the transaction cost and institutional theories. Transaction costs theory (Coase, 1937; Williamson, 1975) contends that the fundamental motive of organizations in choosing their governance structure is efficiency, and that organizations try to optimize the structure and processes for effectiveness within given institutional constraints. Institutional theory suggests that in the face of uncertainty organizations tend to adopt 'taken-for-granted' approaches to legitimize their own (DiMaggio and Powell, 1983; Lawrence and Shadnam, 2008; Jeyaraj and Zadeh, 2020). The consolidating framework holds that the efficiency and effectiveness of cyber security governance is not the only concern of organizations. For them, it is also important that their cyber security governance is legitimate. We investigate how the motive for efficiency and effectiveness is balanced with institutional forces in the configuration of the 5 LoA.

Based on these theoretical premises, we derive two research questions (RQ):

*RQ1: What are CS governance configurations vis-à-vis the five lines of accountability?*

*RQ2: Why does it matter whether the five lines of accountability are adopted?*

As organizations rarely provide public information regarding their approach to CS governance, we undertook an exploratory study to address the research questions through field research in different organizational contexts. We conducted 24 interviews with respondents in positions critical to CS governance and risk management in five large and exposed organizations in different industries. One participant is a European bank where the updated TLM structure is mandated by regulation. We adopted a constructivist approach (Lincoln et al., 2011) and applied the qualitative analysis method of Gioia et al. (2013) to better understand CS governance and risk management. We thus develop and present an understanding of CS governance and risk management informed by those whose roles

[1] With the exception of Steinbart et al. (2018) who consider second- and third-line collaboration.

underpin them.

The paper contributes to the emerging CS governance and risk management literature in several ways. First, CS governance research considering CS responsibilities by organizational functions is relatively scant and focused on individual lines of accountability[2] as opposed to a structure as a whole. However, Enterprise Risk Management (ERM) is not a strictly serial process (Walton et al., 2021) and the 5 LoA are not orthogonal, but inter-related. Our study addresses the need to investigate the combined functioning of the 5 LoA by outlining the accountabilities organizations assign to various roles, how these roles interact to progress CS (Wilkin and Chenhall, 2020; Eulerich, 2021), and who has formal and informal authority over CS decision-making (Aghion and Tirole, 1997). In studying the *type of the 5 LoA adoption* in CS governance configuration, we develop a two-dimensional scale defined by (i) segregation of lines and (ii) level of engagement in the roles contained in the 5 LoA. We identify four types of adoption including 'no', 'ostensible', 'implicit', and 'explicit' adoption. Second, our study develops a *model of factors* influencing CS governance configuration and the adoption of the 5 LoA structure by proposing how institutional factors (DiMaggio and Powell, 1983; Jeyaraj and Zadeh, 2020) and efficiency/effectiveness motives interact in the configuration of CS governance structures (Roberts and Greenwood, 1997). Third, we develop a *pathway model* of how CS governance configurations evolve over time. This model considers the interplay between the institutional forces and efficiency/effectiveness motives to provide insights into the evolutionary and fluid nature of CS governance.

In the next section we present the normative 5 LoA and review the less researched role of executive management and the BoD. We then identify a framework setting out how institutional forces and efficiency and effectiveness motives affect the adoption of 5 LoA. In the third section, we describe our method. The fourth section presents our findings and the model of factors affecting the adoption of 5 LoA. In the fifth section we discuss the findings and present a pathway model addressing how the CS governance configurations evolve over time. We then identify opportunities for future research and practical implications of our findings before concluding the paper.

## 2. Literature review

### 2.1. Five lines of accountability in CS governance

At a high level, corporate governance focuses on relationships between corporate stakeholders. It provides the accountability structure for setting, attaining, and monitoring the company's objectives (OECD, 2015). CS is a prominent emerging area of governance (Sambamurthy and Zmud, 2000; Wilkin and Chenhall, 2020), although the configuration of CS governance is a matter of some debate, but mostly in professional publications (IIA, 2016).

This study focuses on the structural and relational governance mechanisms of IT governance (Van Grembergen et al., 2004) and thereby addresses two distinct but related questions. Governance *structure* focuses on the question, 'Who has what role in how decisions are made?' whilst *relational mechanisms* address the question, 'Who collaborates with whom, and how do they monitor each other?' Relational mechanisms deal with formal and informal authority (Aghion and Tirole, 1997) and include cooperation, strategic dialogue, and shared learning among corporate executives, IT management, and business management (Peterson and Van Grembergen, 2004; Van Grembergen et al., 2004).

The 5 LoA provide the basis for identifying the structures, roles, and accountability needed for CS governance. In the CS context, the first line is the front-line IT function accountable for the implementation of controls to protect the organization from cyber-risks. The second line represents tactical oversight in charge of establishing risk management policies, monitoring the first line's controls, and ensuring compliance with CS regulations and IT/CS risk management policies. Second line roles include ERM, compliance, security, and quality assurance functions. The third line – the internal audit function - is independent of management and does not take part in management decisions (Héroux and Fortin, 2013). It provides *"independent and objective assurance and advice on the adequacy and effectiveness of governance and risk management"* to the BoD (IIA, 2020, p. 3). The three lines are not necessarily hierarchical but can operate concurrently (IIA, 2020).

Executive management is proposed as the fourth line of accountability (Eulerich, 2021; Lyons, 2011; Leech and Hanlon, 2016; Rothrock et al., 2018; Stafford et al., 2018). Executive management has the responsibility to manage the organization and allocate resources to the management of various risks. It develops, endorses, and oversees ERM (COSO, 2017) and ensures that the first three lines have the necessary competencies and perform to expectations. As cyber risk management is only one of the ERM areas, executive management is responsible for aligning it with other areas (Deloitte, 2015).

Most prior research finds that having executives (CEO, CFO and CIO) with IT expertise or an IT executive on the management board significantly reduces reportable data security breaches (Feng and Wang, 2018; Haislip et al., 2016; Haislip et al., 2020; Haislip et al., 2021; Vincent et al., 2019; Smith et al., 2021). One exception is the study of Haislip et al. (2021) which found having a CEO with IT expertise can lead to higher incidence of cyber breaches, although this is considered due to their being more likely to detect and report cyber breaches.

The BoD is the fifth line of accountability that endorses an organization's risk appetite and oversees whether the executive management operates within the organization's tolerance for risk. Its strategic role requires the BoD to participate in developing and refining key strategic objectives (e.g., setting risk appetite) and risk metrics, specify risk assessment rigor, and ensure the independence of assurance (Leech and Hanlon, 2016; Von Solms and Von Solms, 2018).

[2] Examples of studies about the role of *internal auditors*: Dzuranin and Mălăescu, 2016; Islam et al., 2018; Kahyaoglu and Çaliyurt, 2018; Héroux and Fortin, 2013; Slapničar et al., 2022; of *IT and security experts*: Kappelman et al., 2017, 2016; of *external assurance providers*: Stafford et al., 2018; of *management*: e.g., Vincent et al., 2019; Haislip et al., 2016; Haislip et al., 2020; *and of BoD*: Higgs et al., 2016; Lankton, 2021.

While evidence indicates a predominantly positive effect of executive managers with IT expertise on cyber breaches, a handful of cyber security *governance* studies offer no conclusive evidence about the board's role. Prior research has found that already in matters far less technical than CS risk management and oversight, BoDs are relatively passive and mostly engaged in noting the reports and routine monitoring (Machold and Farquhar, 2013) rather than challenging executives (Peck, 1995; Freeman and Peck, 2007; Parker, 2008). Most often, BoDs deal with CS oversight in specialised committees (typically IT or audit). Higgs et al. (2016) investigated whether the creation of a board-level IT committee signals the firm's ability to detect and respond to security breaches and found the opposite. However, the market reacts less negatively to data breaches if an organization has such a committee. Only under half of the S&P boards clearly define monitoring of operational risks (such as cyber risks) in their charters (Harrast and Swaney, 2019). Benaroch and Chernobai (2017) analysed whether operational IT failures, which among others indicate inadequate BoD's oversight, elicit replacements of board members to improve a board's IT competencies and found that predominantly only CIOs get replaced as the scapegoats of IT failures, and not non-executive directors. Vincent et al. (2019) found a positive effect of the BoD's involvement and its IT expertise on the level of CS risk management maturity. Lankton (2021) explored disclosures of directors' involvement in IT governance in the audit charter. They expected that data breaches would positively affect such disclosures but found a negative effect.

In practice, gaps or overlaps exist among the first, second, and third line (Soomro et al., 2016). Furthermore, a significant disconnect currently exists between the information provided by the IT operational levels and its understanding by the BoD and executive managers (Gale et al., 2022). A concern is that because of this disconnect, not everybody in the lines of accountability performs their role effectively, and so the lines are not well aligned and integrated. Moreover, the fourth and fifth line (management and the BoD) have insufficient competencies and often struggle to understand CS reports, which leads to lax accountability that undermines effective cyber governance (Nasdaq and Tanium, 2016; McKinsey Global Survey, 2018). The question then is, to what extent formal authority reflects real authority (Aghion and Tirole, 1997).

### 2.2. *Efficiency/effectiveness vs legitimacy motives to explain the 5 LoA adoption*

In explaining why organizations adopt the 5 LoA, we rely on two theories and a consolidating framework. The first one is transaction costs theory (Coase, 1937; Williamson, 1975) contending that organizations behave rationally and implement structures and processes that economize on the transaction costs of organizing the firm (Williamson, 2007). Transaction cost theory views organizational structure through an economic and legal lens (Williamson, 2008). Firm owners structure the organization to optimize performance and so maximize profit (Young, 2013). Applied to cyber security governance, the adoption of such a model would occur if it is also efficient as it is well aligned with the organizational characteristics, environment and organizational structure. A common criticism is that this approach is an 'undersocialized' account of what actually occurs (Granovetter, 1985; Roberts and Greenwood, 1997; Young, 2013). That is, transaction cost theory takes almost no consideration of the social or institutional context in which organizations operate.

The second theory is institutional theory (DiMaggio and Powell, 1983; Lawrence and Shadnam, 2008) suggesting that decisions about new practices draw on taken-for-granted practices or those that are the most acceptable (Roberts and Greenwood, 1997). Adopting a recognized governance model can become a way of *legitimizing* an organization's approach (Power, 2009), and in the face of uncertainty this need might be fundamental to organizational choices in configuring their accountability and responsibility for CS governance and risk management. A common criticism of institutional theory is that it is 'oversocialized' (Granovetter, 1985; Roberts and Greenwood, 1997). That is, institutional theory takes almost no consideration of the organization's economic context.

While the two theories seem contradictory, Roberts and Greenwood (1997) consider them complementary as organizations optimize efficiency and effectiveness given the institutional pressures. The authors integrate the two theories as the *constrained-efficiency* framework. To understand whether a risk management framework can foster efficiency, the model by Gordon et al. (2009) is insightful. These authors argue that ERM will positively affect firm performance if it is well fitted to firm's environmental uncertainty (e.g., cyber risk exposure), industry competition, firm complexity, firm size, and BoD monitoring. The 5 LoA is a *risk management framework* in which the BoD's monitoring is considered as one of the accountability lines and not as an exogenous factor. We hence consider that organizations pursuing efficiency and effectiveness adapt their governance structure to environmental uncertainty, industry competition, firm complexity, and firm size. Below we theorize how institutional forces affect the adoption of the 5 LoA in configuring CS governance and how they interact with the efficiency and effectiveness motives.

According to institutional theory, laws and regulations represent *coercive* pressures that an organization needs to comply with, to avoid legal penalties (Burdon and Sorour, 2020). In CS, general or industry-specific regulations regulate information security, security breach notification and reporting (e.g., the European Union General Data Protection Regulation [GDPR]; Notifiable Data Breach Scheme in Australia; Sarbanes-Oxley Act [SOX]; AICPA's CS risk management reporting framework, 2017; SEC's 2011/2018 cybersecurity risk disclosure guidance). Other sources of coercive pressures are industry, vendors', and customers' requirements, such as requiring the adoption of Electronic Data Interchange systems (Wallace et al., 2011), the PII (Personal Identifiable Information) or Payment Card Industry Data Security Standards (PCI-DSS) (Malhotra, 2018).

How organizations configure their CS governance is not regulated. An exception is the prudential regulation in banking. For example, the European Union's Directive 2013/36/EU and its 2019 guidelines for information and communication technology (ICT) and security risk management require the independence of the information security control function (the second line) through

segregation from operational processes and its direct reporting line to the BoD. Somewhat similar regulation exists in the Australian context through the Australian Prudential Regulation Authority Prudential Standard CPS 234 Information Security. Internal audit standards with 'force of law' status also mandate the independence of internal auditors (IIA, 2013). However, as data breaches may involve significant penalties[3] and fiduciary responsibility of board members, organizations might adopt structures and processes presented as best practices by the professional associations to demonstrate that their cyber governance and risk management is carried out with the necessary duty of care.

While regulation is tightening, we suggest that coercive pressures represent a bare minimum in most industries. In the banking industry, on the other hand, the 5 LoA adoption is mandated and provides the license to operate. In such instances, coercive pressures compel the organization to be conspicuous in adopting the 5 LoA model. However, even the prudential regulation allows for managerial discretion and calls for a structure that is proportionate to an organization's exposure, complexity, and resources; that is, it accommodates the efficiency of governance configuration. In non-regulated industries, the efficiency and effectiveness motives are likely to prevail and lead to simpler CS governance structures that fit organizational structure and ensure agility. They might allow for the roles to be blended or even to not exist. In these cases, the organization does not face the same pressures to be seen to adopt the 5 LoA model.

*Normative* processes are associated with professionalization, which defines the methods of work in a specific profession (DiMaggio and Powell, 1983). Normative forces arise through formal education, professional certifications and ongoing training, and membership of professional networks (Vuko et al., 2021) and adhesion to professional standards[4]. Professional associations have intensively promoted the 5 LoA, with IIA and ISACA educating risk management, audit, and IT governance professionals for nearly three decades. CS certifications and training influence professionals' opinions as to which risk management approaches are legitimate (Barton et al., 2016). If certified professionals have influence in designing CS governance structure, they will play a decisive role in promoting the adoption of the 5 LoA model, or at least the first three lines if they do not have influence on the engagement of management or the governing body. Ultimately, it is the governing body that decides on the governance structure. Adoption of the 5 LoA can be ascribed to normative forces only if the executive managers and directors themselves know of it, and for this to occur they need significant expertise and formal training.

Finally, *mimetic* processes are present when organizations seek to imitate similar organizations believed to be successful and/or legitimate (Ogbanufe et al., 2021). Mimetic forces are particularly strong when an organization faces high uncertainty, ambiguous causes, and unclear solutions (DiMaggio and Powell, 1983). They arise through professionals circulating across organizations; directors, serving on different boards; and knowledge transfer by reading the same professional articles or hiring the same industry experts (Lin et al., 2020). However, mimetic forces might not stimulate adoption of the 5 LoA but a simpler structure. The efficiency and legitimacy motive strongly interact in such decisions. We argue that when another organization's governance structure is emulated but adapted to consider the size, complexity, industry competition and risk exposure of the organization, legitimacy motives accommodate efficiency/effectiveness motives. For example, large and complex organizations may adopt the 5 LoA as that is also efficient because enough experts are employed in well-segregated roles. For smaller, less exposed, and less complex organizations, such a structure might be seen as disproportionally expensive, rigid, and not fitting their context.

This discussion provides a basis for conceptualizing the governance configuration choices (Fig. 1). It identifies the normative structures to be compared to the organizations' actual choices of structures and relational mechanisms (De Haes and Van Grembergen, 2009). This conceptual framework informs the research approach and method adopted in this study.

## 3. Method

### 3.1. Field research approach

In line with our research aim, a constructivist approach was adopted to provide an understanding of cyber governance configuration (Lincoln et al., 2011). Constructivist approaches provide an authentic observation of actual practice as constructed by the involved social actors (Constantino, 2008; Lincoln et al., 2011), and focus less on explaining the phenomena and more on the development of understanding. We conducted field research with five organizations in different sectors, all with high exposure to CS risks, but in different contexts.

We targeted 3–5 key senior individuals in each organization responsible for delivering, risk managing, and assuring CS risks as part of the first (e.g., security operations), the second (e.g., compliance monitoring/risk management), and the third (e.g., internal audit) lines as well as executive managers and Board members as the fourth and fifth lines respectively. To recruit our respondents, we adopted a purposeful sampling technique (Patton, 2014) and identified suitable candidates through strategic relationships between potential organizational respondents, the authors' research institution(s), and the authors themselves.

Interviews were based on a semi-structured interview protocol (Marshall and Rossman, 2011) that followed a common theme, but tailored for each respondent's position. Each interview was scheduled for about 60 min. Interviews were recorded and transcribed with the permission of each respondent, or detailed field notes were taken if permission was not provided. All interviews were voluntary, and the transcriptions were de-identified and anonymous. The interview protocols are provided in the Supplement for this study. The

[3] GDPR, for example, stipulates a maximum of EUR 20 million or 4% of global turnover of penalties for data breach.

[4] Control Objectives for Information and Related Technology [COBIT by ISACA], CS standards issued by International Organization for Standardization [ISO 27001/2], the standards issued by the U.S. National Institute of Standards and Technology [NIST, 2018], or others.

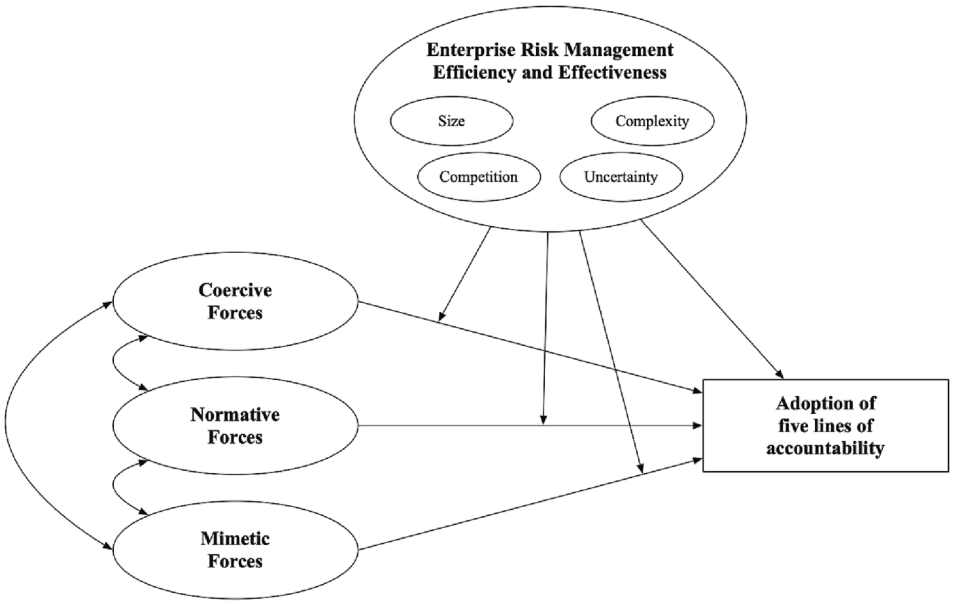


**Fig. 1.** The conceptual framework of the adoption of the five lines of accountability.

study has obtained ethical clearance from its authors' university.

### 3.2. Participating organizations

We targeted and recruited five prominent large organizations to participate in this study. Four participants are Australian organizations in different industries, whilst the fifth participant is a systemic bank in the Eurozone. Table 1 provides background information for these organizations.

The Bank was recruited to represent a context of tight risk management regulation, as it is subject to regulation by the EBA, the prudential regulation of the European Central Bank, and the GDPR. Appendix A sets out the function, role, and background of respondents.

### 3.3. Coding process

Each interview transcript was initially coded in line with our conceptual framework (Fig. 1) to reflect the efficiency/effectiveness motives and institutional theory forces. We therefore coded to identify the efficiency factors (size, complexity, risk exposure, and competition) and the coercive, mimetic, and normative pressures and effectiveness and discussed by participants.

As exploratory research, we also used open coding (i.e., not coding to the conceptual framework) to identify additional statements

**Table 1**
Brief description of participating organizations.

| | Organization A | B | C | D | E |
|---|---|---|---|---|---|
| **ORGANIZATIONAL CONTEXT** | | | | | |
| Industry Sector | University (Tertiary Education) | Health (Government) | Retail Conglomerate (Retail) | Corporate IT Service Provider (Australian branch) | Bank (Europe) |
| Annual Revenues | AUD 2.1 bn | AUD 21.8 bn | AUD 2.8 bn | AUD 1 bn | EUR 865 m (AUD 1.4 bn) |
| Total assets | AUD 4.6 bn | AUD 4.5 bn | AUD 2.9 bn | N/A | EUR 19.5 bn (AUD 31.5 bn) |
| Number of Employees (Approximate) | 7,000 | 79,200 | 13,000 | 2,100 | 8,800 |
| **RESPONDENTS = 24** | | | | | |
| 1st and 2nd Line | 2 | 2 | 2 | 2 | 2 |
| 3rd Line | 1 | 1 | 1 | | 1 |
| Executive management | 2 | 1 | 2 | 1 | 1 |
| Board Member | 1 | 1 | | | 1 |
| **TOTAL COUNT:** | 6 | 5 | 5 | 3 | 5 |

of research interest and built a data structure to conceptualize the configuration of CS governance. We started with the initial coding of the statements made in each of the 24 interviews. We then adopted the approach of Gioia et al. (2013) to build a rigorous data structure presenting first order concepts, second order concepts, and aggregated dimensions. Altogether we identified 57 first order concept codes and 19 s order concepts that aggregated to six dimensions. The data structure constructed from the interviews is presented in Appendix B. The coding identified the governance mechanisms in place and mechanisms addressed within the 5 LoA and other relevant operational areas. Overall, the data structure that emerged provided supported and informed our findings.

## 4. Findings

### *4.1. What are CS governance configurations vis-à-vis five lines of accountability?*

#### *4.1.1. Governance structures*

*First and second line roles*

In participant organizations, the first and second line roles were commonly blended, or worked closely together. Often these two roles were hierarchical, but a role with responsibility for monitoring controls and setting cyber policies might have included several first line functions.

The distinction between first and second line roles was often unclear. Most frequently, we found the first line to include business units such as a Security Operations Centre (SOC) and activities such as incident detection and response, vulnerability management, vendor management, penetration testing, selection and implementation of security controls, development operations (DevOps), security architecture, system automation, testing of security products, process development around specific topics and areas (e.g., phishing), etc. The second line included cyber and information security compliance functions, cyber risk management, monitoring of cyber security controls, and developing policies, protocols, and procedures. From a risk management perspective, respondents highlighted that a major function of the second line was to understand the organizational degree of exposure to cyber-risks, which the top executive in cyber security (e.g., CIO, CISO) then reported to the BoD by concisely synthesizing the main threats.

The second line also made important defensive decisions regarding the digital footprint of the organization and, in general, around how to change the attractiveness of the organization's systems to external attackers. Second line roles might also have held responsibility for business continuity plans and disaster planning, or the CS manager might be a part of the team, managed by a different function in the organization. In the healthcare organization (B) and the University (A), this function sat within the risk management areas and not within the CS or IT departments as they addressed broader risks.

Another important responsibility in which both lines participated was to determine appropriate Key Performance Indicators (KPIs) for reporting to executive management and the BoD. In general, though with some exceptions, the participating organizations had a low level of maturity around the establishment of such metrics. In most cases, a CS reporting Dashboard was considered an ongoing work-in-progress. This indicated a growing sensitivity to this type of cyber-risk management instrument. An indication of the frequency of such reporting is useful in determining the importance of cyber-related matters to the top organizational leaders.

The accountability structure depended on the *size* of the organization: the larger and more complex the organization, the greater was the number of units within each level that were hierarchically or horizontally configured. The clearest segregation between the first and the second line was observed in the bank (Organization E) and the University (Organization A). Exposure to cyber threats (environmental uncertainty) was also mentioned as a factor in the amount of resources an organization was prepared to invest in CS risk management ("*Horses for courses*", C3, executive management). Often, the second line role represented a relatively small, centralized team. However, the role still leveraged sub-units within the different business units, including, for example, regional security officers, security points of contact and the local CISO's teams.

Some participating organizations had complex matrix structures because of their size and geographical segmentation. They had one CISO at the regional level and one CISO at the service level (Corporate IT services provider, D), or a Group CISO that coordinated activities of a CISO in the parent bank and in each subsidiary (Bank, E). As the governance configuration was arranged in a matrix, most positions had two reporting lines. In the Retail Conglomerate organization (C), CS risk management functions of the first and the second line were divided into two horizontally arranged units: 'Security and Operations' and 'Safety and Security', sharing various responsibilities in CS.

In principle, second line roles also comprise the general risk management function. CS and risk management functions collaborated to various extents in different participating organizations. For example, at the University (A), we observed the CIO's awareness of the ERM policies and criticality thresholds for risk levels in the risk control matrix, overall risk strategy, and risk appetite. While the two functions operated separately on a daily basis, they were jointly managed by the Chief Operating Officer (COO) to whom they both reported. Because of the importance of CS and the CIO's level of expertise, he also reported directly to the University's Senate Risk and Audit Committee.

One aspect of CS risk management is the intensive reliance on external providers such as security operation centers, software vendors that provide information on emerging software vulnerabilities and patches, and intelligence partners that provide an updated view of cyber risk exposures and external benchmarks. The involvement of the external providers was managed by different lines depending on the service provided.

*The third line – Internal audit function*

Most respondents, other than the internal auditors themselves, saw the internal audit function as not critically involved in CS risk management to the extent that some organizations did not see fit for us to interview the internal auditor. The exception was the Bank (E), where the IT audit function with their ten employees was highly regarded, and each IT auditor had two cyber certifications.

Nevertheless, a recurring comment that emerged from the other organizations was that internal audit rarely had the competence and expertise specific to auditing CS and instead covered the broader IT and information systems remit.

In line with this, the outsourcing of CS audits emerged recurrently in our data except for the Bank (E). Consequently, the primary role of the internal auditor was to manage relationships with the external audit service provider, enable access to required sources of information, and make sure services were delivered to the expected standard. In contrast to how respondents in other lines perceived internal auditors, however, an internal auditor noted:

> *"Internally, we have a fair bit of experience in cyber security reviews, but we chose to co-source – due to resource constraints in terms of numbers, capability constraints, and political reasons as well. […] The bit that we lack is the ability to benchmark against other organizations. To do maturity assessments. Big Four do many of cyber audits and have benchmarks"* (A6, IT auditor).

Several respondents detailed typical tasks which their internal audit team would perform. Most tasks revolved around assessing the major risks for the organization (either by conducting an internal risk assessment exercise or by re-using information collected at various other organizational units), determining whether appropriate risk controls were in place, and assessing the effectiveness of the existing controls. The bank's IT Auditor described:

> *"We rather focus on risk assessment and governance than on technical controls. In these times, it is impossible to check every control. It is much more important that processes are laid out well, automated and, in fact, implemented. If we focused on a single control, we wouldn't reach far"* (E1).

An emerging topic regarding internal audit was the growing 'thirst' for data that such functions should have. One respondent explained that more data analytics capabilities were progressively deployed in their organization to provide internal audit teams with more reliable, 'live' data regarding the audited risks and associated controls. Again, a close collaboration with the cyber security teams (e.g., the first line) or compliance and governance functions (e.g., CISO) was described as crucial to the success of auditing.

*The fourth line – executive management*

In different organizations, second line roles reported to various executive managers (that is, to the COO, Chief Finance/Risk/Legal/Compliance Officer or even directly to the BoD). Moreover, various second-line roles often reported to different senior managers within the same organization. Decentralized reporting of all three lines was re-integrated on the level of specialized committees that involved diverse executive managers, including some or all of the following: Chief Executive Officer, Chief Finance Officer, Chief Compliance and Legal Officer, Chief HR Officer, COO, CIO. Such committees had various names and dealt not only with CS, but also with general audit, compliance and/or risk management. The committees met monthly, bi-monthly, or quarterly to discuss organizational risk exposure, developments in the industry and organizational performance in cyber risk management. Because of rapid developments, the committees were actively involved in overseeing the development of policies or improvements of risk metrics. However, CS reports at this level were condensed to key risk metrics which did not seem to be integrated with ERM.

It is therefore not surprising that executive managers and security managers from the first and second lines within the same organization perceived cyber risk management maturity differently. In all organizations, CS risk management reporting was bottom-up driven:

> *"You have to understand your audience to ensure you're messaging correctly. I've got to present sufficient content to the board to the executive audience but tailored as to what I think is pertinent and what I think you can reasonably infer from the various points that I've provided"* … *"The majority of executives have an awareness of cyber security but lack any depth of understanding. So, they heavily rely on subject matter experts"* (D3, CISO).

In contrast, the tone from the top was better articulated in the Bank, where the Bank's Risk Committee Chairman (BoD) and the Bank's CRO had come to realize that reports filled with technical details were not fit for purpose. The executive management had tasked the new CISO and the Group CISO to develop more meaningful reports addressing the bank's cyber risks through tangible KPIs and linking them to the CS strategy and processes.

*The fifth line – the board of directors*

The final line is the BoD that is supposed to provide leadership in and oversight of CS risk management. We interviewed the chairperson of two Audit and Risk committees – one at the University (A), and another at the Bank (E). In the University (A), the following quote illustrates how the chairperson actually saw their role:

> *"What we are expected to do is to make sure that we understand the risks and that we have the right people on board"*…. *"The Board is not responsible for the ERM problem; the Board is responsible for ensuring that management has an appropriate ERM framework. The Board is responsible for ensuring that they have sufficient resources in this technology area to cover themselves up for cyber"* (A2, Chairman of the Audit Committee).

While the CIO directly reported to the Audit and Risk committee regarding CS four times per year, the University Senate itself did not discuss CS. The respondents from organizations B, C and D advised that their BoDs were reported to by the chairperson of the executive management's risk committee, directly by the CIO, by internal auditors, and/or by independent assurance providers. In contrast with more established oversight areas (e.g., financial performance) where non-executive directors had established competencies and understanding, in the area of CS they did *not* set expectations and had little involvement in strategizing, defining the risk appetite, and/or influencing which KPIs were reported. Most members of the Board's Risk and Audit Committee were accountants and law professionals who typically had little or no knowledge of CS. This created further challenges as to how and what to report to them. While executive managers (4th line) contributed to the development of meaningful CS reports, we found that BoDs did not do so. Their

discomfort with the reports, either due to their lack of understanding or because they needed to benchmark internal KPIs to better understand CS threats, resulted in the frequent need to hire an external consultant to provide such advice and assurance.

However, the bank had recruited a Chief Data Science Officer of another bank to the Board, and the chairperson of the Risk committee also came from a technical background. Furthermore, the chairperson had completed CS training at a renowned University. He noted:

> *"Cyber risk is the most imminent and the most significant risk at the moment, in the absence of credit and liquidity risk, it is actually the top risk that we are facing"* (E2).

The reporting on CS risk management matters to the Bank's BoD was extensive (but somewhat diffuse) through three committees: the CISO reported to the Risk committee as well as the Operations and IT committee, and the internal auditor reported to the Audit Committee.

#### *4.1.2. Governance relational mechanisms*

Our respondents often discussed an intense collaboration between the first and the second lines, particularly between the security professionals and CIO/CISO, but not so much with internal auditors as the third line. It seems that the independence of the internal auditors is at the cost of their perceived relevance to second line managers, executive managers, and BoDs. For their part, internal auditors noted that cyber risk management was not mature enough. This resulted in some critical tasks being performed twice, that is separately, by the second and the third line:

> *"Ideally, risk management would do a risk assessment. But they're not quite at that maturity level. In an ideal world, we'd want to rely on competent management. In the absence of that, we have to do the best calculation of risk. And applying the ERM framework is not perfect (too high level), so we have to fill in the gaps"* (A6, internal auditor).

Such a lack of trust and cooperation may cause both duplications of work and gaps between the three lines and the ERM managers. The perception of the internal auditor's role was different in the Bank. We did not observe any lack of trust in internal auditors' competencies. The bank's BoD and the other lines expected the internal auditor's role to be more about *"pointing out the shortcomings of the processes than testing technical controls"* (Chairman of the Risk Committee, E4). While formally segregated, the level of informal communication between the lines was boosted as the managers in the first three lines frequently met with each other and had offices near to each other. In the healthcare organization (B), the Deputy Chair of the Audit and Risk Committee said that in his view *"…there has to be a strong, strong flow and really good working relationship between risk and audit"* (B5).

Given the asymmetry of information and competencies of the CS managers vis-à-vis executive management and the BoD, CS risk management reporting was in all institutions bottom-up driven. Our respondents, particularly CISOs/CIOs, indicated that they had very little guidance from the top and received only a very high-level statement of requirements. They were also aware of the imbalance of knowledge. Often, the second line roles followed the principle of 'management by exception' and escalated a problem only when they felt it was appropriate so as not to alarm the board too frequently and too quickly.

It was also mentioned that much less information was reported to BoDs than to executive management. Consequently, executive managers and the BoDs exhibited an overdependence on a CS manager.

When searching for independent assurance, the BoDs seemed to prefer an external provider, but these service providers were only engaged every few years. The BoD's predominant concern was to understand how mature CS risk management was, whether the level of investment was comparable to peers and what the emerging threats were. The information provided by internal auditors about how well the organization complied with its CS policies, strategies, framework and how well CS risk management was aligned with ERM (that is, on the status quo) seemed of secondary interest. Again, the exception was the Bank (E), which hired external consultants to a limited extent (threat intelligence) and invested significantly in internal capabilities. Frequent changes in positions on the first two lines had somewhat slowed their development.

The disconnect between the first two lines and the third led to sub-optimal cyber risk management. Multiple risk assessments, disparate thresholds for the criticality of various risks, no integration into the ERM's risk matrix, inconsistent maturity evaluations by different parties, and fragmented reporting to the upper echelons were apparent. The informal power stemming from competencies and significant information asymmetry ultimately placed a disproportionately large dependency on a single individual in cyber risk management. The quote by the Deputy Chair of the Audit and Risk Committee in the Health Care organization (B) is representative of the blind faith boards and executives seem to have in their CISOs:

> *"I recall him as being highly capable, competent and calm. He came from a military background, so when you felt like the walls were falling down around you, he would just calmly sit down, talk through the issues, talk about the treatments, talk about what they're doing, and got on things. He's very, very good in his position. He was then grabbed obviously by consults and then sold back to us at a high rate."* (B5)

Coupled with misperceptions of others' roles and the mistrust in competencies, these informal relations shed a somewhat different light on the functioning of the formal structures.

#### *4.1.3. Defining the type of 5 LoA adoption*

Our core research question is why it would matter for organizations to adopt the 5 LoA. To answer it, we first define what it means to adopt the 5 LoA model in configuring CS governance. We conceptualize the type of adoption according to two dimensions. The first dimension is the *segregation of lines* – that is, maintaining the independence of the roles responsible for setting up controls from those

monitoring them. There are four aspects to consider in practice. The segregation of lines can be assessed by considering the extent of segregation of the second line from the first line to ensure objective monitoring. The independence of the third line from the first two to ensure independent assurance is also a prominent aspect of this assessment. Further, the second and the fourth line can be segregated to a varying extent – for example, including or not including the CIO in executive management. The final aspect relates to defining a clear role separate to that of executive management for the BoD in the oversight and establishment of a direct reporting line from the second and third line to the BoD (EBA, 2019). In practice, the segregation of lines ranges from blended to segregated.

The second dimension is the *level of engagement in the 5 LoA*. Professional publications and guidelines (COSO, 2017; IIA, 2020) and prior research (e.g., Kappelman et al., 2017; Kappelman et al., 2016; Slapničar et al., 2022; Vincent et al., 2019; Higgs et al., 2016) largely agree that engagement of organizational actors at all levels of the organization is a vital element for positive cyber security risk management outcomes. We define engagement as ranging from low to high. Our findings show that the segregation of lines does not automatically lead to higher engagement. Organizational actors may be engaged even if an organization blends some lines. Or, the organizational actors may not be highly engaged in their roles despite the roles being quite formalized and segregated. For example, not all our organizations saw the role of the internal auditor as critical in cyber security risk management; instead, they relied on external consultants or on the second line for assurance. We also consider there to be low engagement when executive management and Board members' roles are limited to only noting the reports received – that is, they do not challenge the report, do not participate in the formation of the cyber risk strategy or do not comprehensively oversee the actions of management.

Our descriptive findings suggests that the two dimensions are not causally related. That means that formalizing the lines may not necessarily elicit more engagement by organizational participants. The combinations of the two dimensions identify various types[5] of adoption of the 5 LoA including "no adoption", "ostensible adoption", "implicit adoption", and "explicit adoption". In line with other research (Eulerich, 2021), "no adoption" occurs where the organization has either not defined the lines or has chosen to blend them and incumbent individuals in most of the lines have little engagement with the requirements of their role. Although no organizational participants in our study were in the 'no adoption' quadrant at the time of the study, participants referred to their earlier approaches to CS governance as lacking maturity or non-existent. On this basis, an organization classified as being in the 'no adoption' quadrant may have a cyber security function, but their governance of cyber security was reactive or lacking a purposeful design.

If instead all lines are formally established and segregated but the individuals in those roles exhibit low levels of engagement, then this indicates an '*ostensible adoption*' of the 5 LoA. An ostensible adoption occurs where, to outward appearances, the 5 LoA are in place and clearly segregated, but the adoption is in fact superficial. That is, the lines of authority are readily discernible, but the level of engagement in those roles is not in fact high.

A counterpoint to ostensible adoption is '*implicit adoption*'. This type of adoption recognizes the flexibility and integration ('blending') of lines possible in adopting the 5 LoA (Eulerich, 2021). 'Implicit adoption' is where an organization that blends some of the 5 LoA rather than segregates them, and where the individuals in the roles of the 5 LoA engage effectively with the 5 LoA. In contrast with ostensible adoption, in implicit adoption the lines of authority are not so readily discernible, but under the surface there is active engagement in the roles set out in the 5 LoA. The final type of adoption of the 5 LoA is '*explicit adoption*', which arises where the lines are clearly defined and segregated, and where all the individuals in charge are engaged and exercise their responsibility and accountability as described in our theoretical background. Explicit adoption arises where there is clear and active adoption of the 5 LoA by the organization.

Both ostensible adoption and explicit adoption adopt a CS governance configuration discernibly in line with the 5 LoA. To external stakeholders, it is apparent that the 5 LoA are adopted in both cases. For implicit adoption, it is not so clear to an external stakeholder that the 5 LoA are adopted, but internally it is clear that the roles are actively engaged with. In this case, higher engagement through more blended rather than segregated roles is seen as more appropriate due to concerns of efficiency and effectiveness. Fig. 2 below represents these different types of adoption of the 5 LoA to describe CS governance configuration according to the segregation of lines and the level of engagement in the lines of accountability.

In the next section, we theorize why some organizations actively adopt the 5 LoA ('implicit adoption' or 'explicit adoption') and others do not adopt the 5 LoA or adopt it in form only ('ostensible adoption'). In other words, we answer the question 'why does it matter whether the 5 LoA model is adopted?' Our model provides a basis for considering how institutional forces balance with the motive for efficiency and effectiveness in the configuration of the 5 LoA.

### *4.2. Why does it matter whether the five lines of accountability are adopted?*

Our findings suggest that in their decision for the cyber governance configuration, organizations strive to achieve two aims: (i) be in compliance with best practices, and (ii) mitigate cyber outcomes in an efficient way. In face of uncertainty, in which the optimal and most effective organizational approach is not known, one of the main reasons for an organization to adopt a certain approach to CS governance is legitimacy. Namely, if governance practices are not legitimate, that might in itself create a cyber risk – a litigation and reputational risk that an organization has not managed cyber risk appropriately. By imitating prominent role models, organizations not only claim legitimacy, but also learn faster as there is an existing template to follow. Below we describe how organizations consciously balance efficiency and legitimacy factors.

[5] We call them types of adoption not levels of adoption to indicate that they are not monotonously increasing.

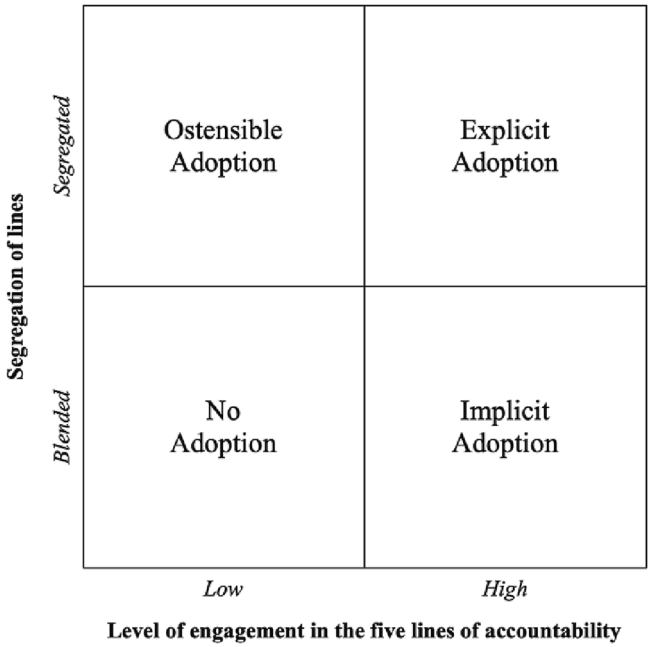


**Fig. 2.** The types of adoption of the five lines of accountability in cyber security governance configuration.

*4.2.1. Mimicking others from legitimacy and efficiency/effectiveness motives*

Among the institutional pressures, we observed that mimetic pressures were quite important and they eventuated through multiple channels. Mimetic forces were apparent from suppliers in the supply chain, other industry participants, consultants, other industry participants, board members and industry associations. This included, for example, vendors who provided software patches or intelligence partners who provided essential input in risk assessment. In contrast with managing other types of risks (e.g., credit risk, market risk), it was typical in managing cyber risk that external providers supplied significant services. This configuration was regardless of how large and complex an organization was, or how competent the professionals in the three lines of defense were. The need to benchmark performance against other industry participants was given as a reason for organizations to mimic others in their industry, as mentioned in the following excerpt:

> *"We hire external consultants. It is very difficult to benchmark performance against the industry because people do not share the data. We collect and report lots of information on attacks in the industry, and we regularly launch educational pieces. When an attack has occurred in the industry, we ask ourselves, 'How does it apply to us'?"* (C2, risk manager).

However, mimicking and benchmarking against others primarily referred to the processes and controls of the first and second line without much consideration of keeping these lines segregated. The emphasis was in the execution of the role rather than mimicking separated lines. Organizations were most concerned about the effective execution of their technical roles, and by that they also meant the possibility to benchmark.

External governance consultants, on the other hand, promoted the 5 LoA model and seemed to have a pivotal influence on the configuration of governance adopted, especially in the association with their assessment of maturity:

> *"We had a [large accounting firm] do an audit on us or not an audit, but an audit and a recommendation of how we should be structured. And they touched on that around the three layers of defense"* (C4, Security and Operations).

In the banking industry, the desire to mimic other banks for reasons of legitimacy as well as for reasons of efficiency and effectiveness to a large extent overlapped. Sharing information between competitors about cyber security practices seemed much more common than in other non-regulated industries. As noted by the CRO of the bank (E4):

> *"Well, you would be astonished, but you simply establish contact and talk with other international banks about cyber and other risks. […] That sounds a little bit counterintuitive because, at the end of the day, it's competition, but these are not competition topics; this is how you make the industry safe. Or how you establish standards which are helpful for everyone, including the clients."*

Mimetic forces appeared very strong in shaping the practices of the third line, where companies engaged the same external providers to conduct cyber security audits. Interestingly, one respondent highlighted some potential downsides of this approach as conflicts of interest could arise that obliged the organization to return to the market to identify other providers. Independence issues also meant that external consultants also performed maturity assessments.

Mimetic forces also manifested through the multiple roles a professional (particularly at the Board level) might hold in different

organizations. For example, a Board member (A2, Risk and Audit Committee) explained that he was a member of other BoDs in various industries and recommended holding a particular 'cyber briefing' on CS for audit purposes. The Bank's Chairman of the Risk Committee (E2) sat on the BoDs of three banks, two of which were designated as systemically important in the Eurozone. He suggested that the banks and their Boards took *"a similar, very similar approach"*. This way, the briefing format was replicated across several organizations according to Board members' input. Emulating practices of other companies also arose by professionals circulating across various organizations and transferring knowledge.

Yet another way organizations mimicked each other's practices was through industry associations. A respondent from the University highlighted how best practices are more easily shared across universities through AusCERT (the Australian Computer Emergency Response Team, a not-for-profit organization providing cyber response services or their members[6]). Similarly, in the banking industry practices and knowledge were widely shared via the national Association of Banks. Here, professionals from all banks involved in IT and cyber risk management shared practices in the Security Forum and the IT Committee. Furthermore 12 banks through the Association of Banks had jointly commissioned a cyber assurance review of an organization that processed payments, which was a critical process for those banks.

Overall, although mimetic forces are found to be a strong factor in the choice of reporting practices and structures in the CS configuration, they do not necessarily mean that roles within the 5 LoA need to be clearly segregated. The efficiency and effectiveness motives strongly interact with legitimacy concerns: organizations compare to others not only to legitimize their level of investment in CS risk management but also to increase the efficiency and effectiveness of their CS risk management. Efficiency and effectiveness concerns became particularly prominent where the organization worked with its industry peers to establish benchmark practices. The decisions about the type of the 5 LoA adoption in configuring CS governance depends on organizations' complexity, exposure and size.

#### *4.2.2. Normative forces moderated by efficiency/effectiveness motives*

Normative forces manifested through the professional certifications, accreditations, and educational background of professionals. Our respondents were characterized by an eclectic portfolio of educational and professional experiences. As expected, professionals with the most technical competencies (with an academic background in Computer Science and/or IT and professional certifications such as CISP or CISM) were placed within the first and the second line (in particular, but not necessarily CISO/CIO).

The academic background of many other second line managers in security and risk management was diverse and ranged from information systems, accounting and finance to other disciplines related to the organizations' core business. These professionals were trained for the job through experience and various professional qualifications (cyber, accounting, safety, and risk management). Internal auditors' academic backgrounds in the participating organizations were not in computer science or information systems but were instead predominantly in accounting. However, within internal audit IT auditors had been trained up to perform cyber audits by acquiring the CISA and other certifications. Of the participating organizations, the professionals in the three lines and the BoD with the most focused cyber qualifications were those at the Bank, suggesting that coercive forces feed into the normative forces and prompt employment and certifications of cyber experts. Overall, for the second and the third line roles experience seemed to count most, while technical competencies prevailed in the first line roles.

The collected data highlighted that the respondents had different degrees of familiarity with the 5 LoA. Despite some respondents being aware of it, its use in organizational practices appeared fragmented; that is, the first two lines were blended, and the lines above were only moderately involved. Some respondents demonstrated an understanding of the applicability of the model depending on the organizational context:

> "*IIA has issued new guidance on the three lines of defense, which is a little bit more flexible. A rigid division of responsibilities between the three lines of defense works for financial institutions that have a large number of employees in those areas, but our organization is smaller and needs more flexibility about how the areas are managed"*. C2 (Safety and Security Manager)

However, some respondents, particularly those with technical backgrounds from the first two lines, did not appear familiar with the 5 LoA nor aware of the segregation of lines. They were more concerned about the speed of reaction in such a structure:

> *"Level one, level two, level three is probably a formula too slow to respond. That structure going up the chain, by the time it gets to someone who actually knows what they're doing, the opportunity's gone"*. B4 (CS Team Manager)

Another respondent similarly considered:

> *"The TLM taxonomy does not suit cyber security; it does not provide sufficient categories to be able to measure results correctly and ensure that you've got the right remediation processes based on the category to drive a particular outcome. So, we're currently trying to align industry standard cyber security taxonomy with group risk"* (D3, CISO).

In addition, rapidly changing circumstances required a rapidly changing definition of roles:

> *"When we set out on this journey, we set it out such that we were going to have a number of roles. Three years later, we've got totally different roles because the nature of the threat has changed, and where that threat is from, and what is required to face it. It is dynamic"* (C5, Chief Information Officer (CIO).

[6] https://auscert.org.au/.

Overall, as the first and second line are not too well acquainted with the 5 LoA but seemingly very influential in configuring the CS governance structure, they are not the driving force to promote 5 LoA. Instead, they seem to be more motivated by efficiency and effectiveness motives and do not perceive any conflict of interests between their two lines that would require strict segregation. The model is more closely followed where managers are familiar with it, whereas the internal auditors who are also aware of the 5 LoA are themselves not well integrated in CS risk management in the participating organizations.

#### *4.2.3. Coercive forces*

We found coercive forces such as those arising from laws and regulations affected the configuration of CS governance in different ways. The Bank (E) operated in the most highly regulated environment and was subject to GDPR and prudential regulations regulating risk management. As a systemic bank in the Eurozone, the Bank was continuously monitored by a joint supervisory team (JST) of the European Central Bank (ECB) and the Central Bank of the country where the Bank was headquartered[7]. Amongst our participating organizations, the bank (E) was the only organization with profound awareness of the need for the segregation of lines. European prudential regulation requires the segregation of lines and a Chief Information Security Offer (CISO) reporting directly to the BoD (EBA, 2019). The bank clearly followed the principle of segregation of lines and had adopted the 5 LoA to the highest extent of participating organizations. In recent years though the Bank's practices exceeded regulatory requirements, and regulation was not felt to be the force that most decisively drove cyber risk management development. Rather, normative, mimetic and efficiency/effectiveness motives prevailed.

Industry security standards (e.g., PCI and PII) are also important sources of coercive pressures in CS risk management. For the Retail organization (C) and the Bank (E) with numerous outlets reliant upon Point of Sale (POS) systems, compliance with these standards is critical. The first line ensured compliance and the second line monitored it. Organizations were also audited annually by an external provider. Owners' own governance channels also exerted coercive forces with State governments and parent companies mandating the use of specific CS frameworks. Coercive forces also occurred where government owners mandated audits.

Concerns about penalties and personal liability were not directly identified as factors that guided the configuration of CS governance structure. Participating organizations considered that following benchmarks and practices similar to their peers provided reasonable protection against civil liability, which is also a mimetic force.

Overall, the coercive force that directly required adoption of 5 LoA was the prudential regulation in banking. However, adoption of the 5 LoA model in this case does not seem due to reasons of legitimacy. Instead, the Bank's awareness of the importance of cyber risk shaped organizational practices to pre-empt regulatory requirements. In fact, the order might be reversed – the 5 LoA model was developed based on governance structures in banks and other large, exposed organizations with resources they can devote to CS risk management.

#### *4.2.4. A model of institutional and efficiency/effectiveness factors for 5 LoA adoption*

From our findings, we conceptualize a model taken by organizations in adopting the 5 LoA according to the efficiency/effectiveness motives and institutional forces that arise in their context. This model represents different types of cyber security governance configurations. Our findings indicate that the efficiency/effectiveness motives significantly moderate institutional forces, which themselves relate to, and feed into, each other. For example, prudential regulations requiring adoption of the 5 LoA developed by the profession itself indirectly influence professionals to obtain certifications and organizations to hire certified professionals. Coercive and normative forces more highly impact the segregation of lines as maintaining these separate highlights the adoption of the 5 LoA and increases legitimacy. If though segregation is not considered efficient, management often tempers it by blending roles or encouraging informal relationships with the result that the 5 LoA are less segregated.

The balance of efficiency/effectiveness and legitimacy factors depends on the organizational context. In Fig. 3, we disentangle the factors assumed to prevail in each quadrant indicating the type of adoption of the 5 LoA. Some factors overlap. For example, the segregation of lines might be induced by the same factors in ostensible adopters and explicit adopters; yet, factors that induce active engagement might differ, e.g. the perceived exposure. The resulting model identifies the factors in the decisions that underly the choices made in choosing different types of cyber security governance configuration.

## 5. Discussion

### *5.1. Explicit adoption of 5 LoA is not common*

Our analysis shows organizations only relatively recently realized the importance of well-defined and transparent structures in CS governance and risk management. While we found upper lines to be more familiar with different accountability lines and acknowledged the 5 LoA model as good practice, they did not favor following the model strictly. Most participating organizations did not segregate the implementation of controls from the monitoring of them. The first two lines were often much more granular and intertwined than segregated with the responsibilities typical of the first and the second line divided among several individuals, functions, and units. Often the second line's responsibility for monitoring controls and providing assurance was mixed with operational tasks. However, independence in the monitoring of controls was ensured by the authority conferred by the formal hierarchy on

[7] The Joint Supervisory Team attended every BoD meeting to monitor governance and risk management and, in addition, conducted regular on-site reviews of risk management below the Board level.

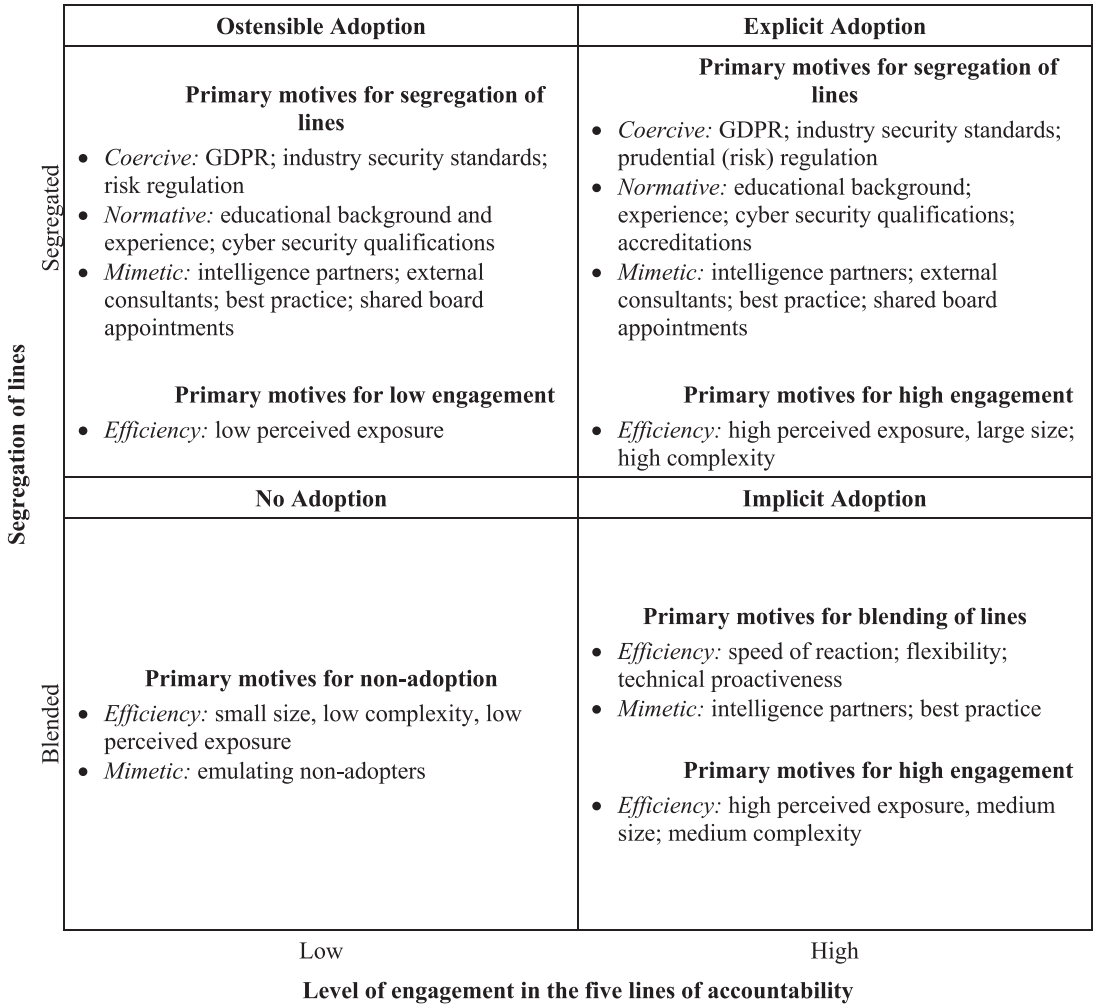


**Fig. 3.** The model of cyber security governance configuration identifying factors in the adoption of the 5 LoA.

CIO/CISO roles acting as supervisors to operational roles. Organizations strived to deliver a holistic cyber capability as *effectively* and *efficiently* as possible. For this reason, they did not segregate the first two lines because the cyber environment changes and is dynamic, people in cyber risk management positions regularly change, and the CS area in organizations is expanding. Organizations therefore frequently changed the governance structures, accountability lines and reporting for the purpose of effectiveness and efficiency.

In terms of providing assurance that CS risk management is effective, the internal auditor's scope was to review it from a process perspective and how it was embedded in the overall ERM. Our findings corroborate the earlier findings of Héroux and Fortin (Héroux and Fortin, 2013) that internal auditors predominantly focus on reviewing compliance with existing policies and frameworks. Although the organizations are much more aware of the need for maintaining the independence of the internal audit function (in line with the 5 LoA), they see its role as rather marginal in CS governance due to the scope and timeliness of the work performed by the internal audit. As the scope of cyber risk management is extensive, the practice of reviewing components of this function annually according to a long-term internal audit schedule means that audit cycles last 4–5 years (Slapničar et al., 2022). This impedes internal audit's ability to provide a holistic assessment of cyber risk management effectiveness on a timely basis.

As to the scope and timeliness of the internal auditors' assurance, rapid changes of organizational structures and environment mean that executive managers and BoDs view the disclosure of material non-compliance with *internally* set systems as less important than the understanding of emerging threats and developments in the industry and whether their organization is on top of them. This view indicates the value of the external assurance provider role. External providers have the advantage of knowing the approaches of other organizations in the industry that operate with similar technologies and are vulnerable to the same exploitation methods (Gilligan et al., 2019) and are truly independent.

While it is acceptable that technical controls are bottom-up driven, governance, risk and compliance need to be orchestrated top-down. Participating organizations recognized the importance of executive management engagement in CS risk management; however, they had a very high-level understanding of CS and received reports containing only high-level information. This impeded the

proactive involvement of executive management. Executive managers were collectively involved in CS risk management in specialized committees and strongly relied upon their CIO/CISO and security specialists. An issue with such 'push' reporting is that the content of reports and the criticality of information is decided by those who manage CS and who may often withhold critical information for too long (Martin, 2014; Srinivasan et al., 2016). Aghion and Tirole (1997) argue that such relationships lead to a difference between formal authority ("the right to decide") and real authority ("the effective control over decisions"), which heavily rests with the CIO/CISO.

Our findings suggest that BoDs have not yet assumed the fifth line of accountability as they are relatively passive recipients of cyber reports rather than in a position to constructively challenge them and provide independent views. To rise beyond what Lyons (2011) calls *"little more than a token box-ticking"*, it would be imperative for BoDs to gain competencies and experience in the cyber/digital/IT areas, as otherwise the fifth line cannot constitute an independent line of accountability. It seems that capital market authorities have started to recognize the BoD's contribution is often too low. At the time of writing, the US Securities and Exchange Commission (SEC, 2022) has proposed new rules requiring disclosures of directors' oversight of CS risk, management's role in implementing CS policies and procedures and managers' and directors' CS expertise. Such regulation is likely to encourage the proactive involvement of executive management and directors in CS governance through pressure from investors and tangible effects on the cost of capital.

All in all, among our studied organizations, none seems to be in the 'No adoption' quadrant (Fig. 4). We classify organizations B (Health), C (Retail chain) and D (IT service provider) in the 'implicit adoption' quadrant due to blended first and second lines and with somewhat less engagement from the executive management and the BoD. We do not classify any organization as having segregated lines and high engagement. The Bank (E) has the clearest segregation between the lines of accountability closely followed by the University (A), but we nonetheless classify them both as somewhat between 'ostensible' and 'explicit' adopters, as they have not fully implemented all the roles. Their CS governance configuration decisions reflect a mixture of legitimacy and efficiency/effectiveness motives.

### 5.2. A pathway model of 5 LoA adoption

A key insight from our findings is that the adoption of the 5 LoA model in the CS governance configuration context is both evolving and fluid. The type of adoption that organizations currently find themselves in and the type of adoption they strive to implement depends on the interactive effects of institutional forces and efficiency/effectiveness motives in the face of the dynamic and changing nature of cyber threats that lead organizations to arrange their CS governance to be fluid – that is, agile and adaptive. Organizations seek more flexibility (Eulerich, 2021) by 'blending' the segregated roles of the 5 LoA model to ensure fast reactions to changing circumstances. However, regardless of the number of lines and the extent of blending of lines, we found that all organizations see scope to improve engagement in the 5 LoA roles.

Based on our findings, we developed a pathway model (Fig. 4) that indicates the type of adoption of the 5 LoA over time and reflects the fluidity of CS governance configuration. The pathway shows where an organization's CS governance configuration has been, and the targeted type of adoption. Institutional forces represent an initial impetus for the CS configuration adopted. That is, an organization with initially immature CS governance will configure their initial adoption of the 5 LoA according to mimetic, coercive, and normative

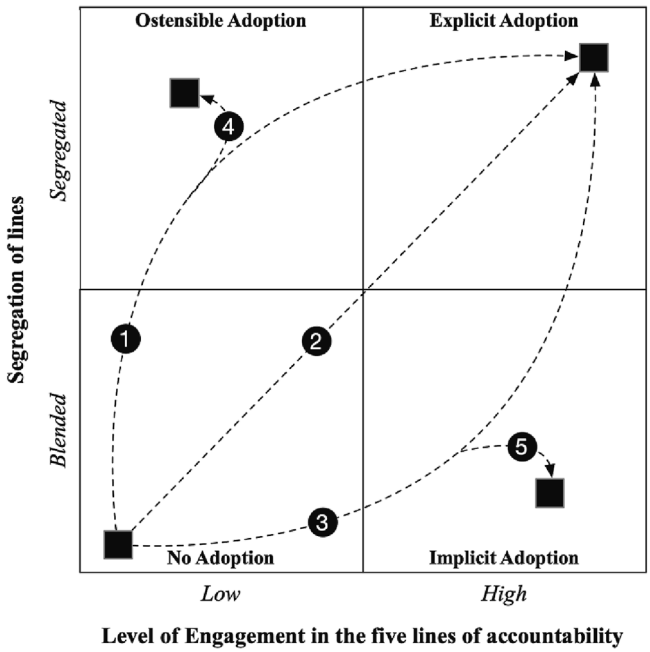


**Fig. 4.** Pathway model to five lines of accountability in cyber security governance.

forces. However, over time the extent of segregation of and engagement in the lines of accountability is shaped by efficiency/effectiveness factors such as size, competition, complexity, or uncertainty. As a true pathway, the CS configuration might then move to adopt other types of adoption over time as efficiency/effectiveness factors shift.

According to our pathway model, an organization may choose one of three primary pathways to adopting the 5 LoA model. Pathway 1 moves from 'no adoption' via 'ostensible adoption' to 'explicit adoption', and this path will be taken if institutional forces predominate over efficiency/effectiveness motives so that segregated lines are formally implemented, but engagement is initially not yet high. Pathway 2 moves from 'no adoption' directly to 'explicit adoption', and this path will be taken if coercive and/or normative forces require segregation of lines while efficiency/effectiveness motives also require high engagement from the executive management and the BoD. Pathway 3 moves from 'no adoption' via 'implicit adoption' to 'explicit adoption', and this path will be taken when efficiency/effectiveness motives are emphasized over institutional forces.

It is important to note that not all organizations aspire to 'explicit adoption' of the 5 LoA model due to their balance of the efficiency motives and institutional factors. Organizations might well remain with ostensible or implicit adoption as this suits their needs. Accordingly, the pathway model represents this choice by indicating pathways that stay within these quadrants (pathway 4 and pathway 5, respectively).

### *5.3. Practical implications, research limitations and future research opportunities*

From a practical perspective, our study offers several recommendations. Organizations need to decide to what extent the adoption of the 5 LoA is warranted in their context to ensure the legitimacy of their CS governance and to maximize the efficiency and effectiveness of their CS risk management. In their decision, they should consider the segregation of lines and the level of engagement in the line roles. With respect to the *segregation of lines*, our findings suggest that agility and efficiency primarily drive the configuration of CS governance. In some organizations the first two lines might remain blended (or there might, in fact, be only one line), because holding them segregated could be too slow to respond and disproportionally expensive relative to their size. Some organizations decide to co-source or outsource some tasks such as, for example, scanning of the environment and identifying emerging threats. Excessive reliance on internal providers for such advice would represent a risk in terms of the ability to 'sense-check' emergent dangers from the environment.

Concerning the *level of engagement in the line roles*, we believe that a higher engagement of upper lines would be unequivocally beneficial. Our common finding was that the role of the internal auditors was not sufficiently integrated in CS risk management to leverage their skills and expertise. Prior research shows that CS risk management can be significantly more effective if the second and third lines collaborate (Steinbart et al., 2018). The competencies of internal auditors are different to those of security professionals, and these competencies could be productively combined. For example, opportunities exist in risk assessment, an area that has been maturing for decades in the internal audit profession, or the quantification of digital assets' value and cyber-attack impacts. At the same time, a clarification of accountability roles is crucial to avoid duplication of tasks or, worst and more commonly, dangerous 'voids' in the assurance function. Enhanced professionalization of the fifth line of accountability (BoDs) (normative forces) could help improve its engagement and facilitate a more holistic management and governance of CS risks. As for the latter, the creation of *ad hoc* CS certifications for board members could leverage the positive perception traditionally associated with cyber-certifications.

Typical of qualitative investigations, findings from our research have limited generalizability. In particular, the organizations participating in this research belong to specific industries, which may not be representative of dynamics associated with CS risk management in other sectors. Moreover, our participating organizations represented one organization per industry, which may limit the applicability of our results to other organizations in the same sector. Another limitation acknowledged is the adopted purposeful sampling approach, which might introduce sampling bias (Patton, 2014). In particular, the selected respondents, due to their competence in CS risk management, might not be representative of practices and perceptions around CS risk management in their organizations. To compensate for these limitations, we have sought to interview more professionals in each organization; further, we recruited large organizations to be able to gain a better understanding of how the accountability lines are 'exercised' in each of them. The third limitation is endogeneity of the proposed model whereby effectiveness can be thought of as an independent variable driving the decisions about CS configurations, but it can also be a dependent variable; that is, the outcome of CS governance configuration.

The study offers several opportunities for future research. For example, the model of factors of the 5 LoA adoption in configuring CS governance and the pathway model of CS governance configuration could be tested through longitudinal and/or cross-sectional analyses. Opportunities are to further examine the moderating relationships between the institutional forces and efficiency motives on CS risk management and governance with structural equation modelling. Last but not least, the question about whether an explicit adoption of the 5 LoA matters for cyber outcomes could be studied by using quantitative methods that can test causality. For example, one avenue of research is whether an express statement regarding cybersecurity risk in a BoD's charter is necessary for effective governance of CS. Similarly, future research might consider whether organizational documentation must outline the 5 LoA to achieve the benefits of the 5 LoA model.

## 6. Conclusion

In conclusion, cyber governance configurations and the relationships between the 5 LoA in different industries have received scant attention in academic research focusing on CS risk management. To the best of our knowledge, this study is the first to examine these topics comprehensively. Our investigation has also cast light on the forces that mainly contribute to shaping these configurations and relationships, offering recommendations for practitioners and researchers alike.

## CRediT authorship contribution statement

**Sergeja Slapničar:** Conceptualization, Methodology, Investigation, Writing – original draft, Project administration. **Micheal Axelsen:** Conceptualization, Methodology, Investigation, Writing – original draft. **Ivano Bongiovanni:** Methodology, Investigation, Writing – original draft. **David Stockdale:** Writing – review & editing, Project administration.

## Declaration of Competing Interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

## Data availability

The authors do not have permission to share data.

## Acknowledgements

We thank all interviewees, Vivian Pontes for her valuable research assistance, and the University of Queensland Business School for the Connect Grant to fund our research.

## Appendix A: Function, level, and background of respondents

| Code | Function | Level | Academic Background/Certifications |
|---|---|---|---|
| A1 | Chief Operating Officer (COO) | Executive Management | Law School |
| A2 | Chairman of Audit and Risk Committee | Board | Master of Commerce, Accounting major |
| A3 | Risk and Governance Manager | 2 | Master of Financial Management, specialist in risk management and fraud |
| A4 | Chief Information Officer (CIO) | 2 | Master of Engineering Science |
| A5 | Cyber Architect | 1 | Bachelor of Computer Science |
| A6 | Internal Auditor | 3 | Master of Information Technology, Bachelor of Electrical Engineering CISA qualification within IAF, but not CAE |
| B1 | Chief Technology Officer (CTO) | 2 | Bachelor of Electronic Engineering, Cyber Security certifications |
| B2 | Chief Clinical Information Officer | 2 | Clinician, Medicine |
| B3 | Internal Audit | 3 | Bachelor of Commerce, CISA |
| B4 | Head of CS Team | 1 and 2 | Bachelor of Business, Master of Computer Science, CISM |
| B5 | Deputy Chair of Audit Risk Committee | Board | Bachelor of Business (Accounting), Fellow of CPA Australia, Chartered Tax Advisor, GAICD. |
| C1 | Head of Security Platforms | Executive Management | Bachelor of Computer Science, Master of Information Technology, CISP, CISM, OSCP |
| C2 | Head of Safety and Security | 1 and 2 | Bachelor of Chemistry, Master of Health and Safety |
| C3 | Chief Finance, Compliance, and Legal Officer | Executive Management | Law School |
| C4 | Head of Security and Operations | 1 and 2 | Bachelor in Accounting and Information Systems |
| C5 | Chief Information Officer (CIO) | Executive Management | Non-IT academic background, experiential learning |
| D1 | Operational Security - | 1 and 2 | Self-trained programmer, no academic degree, experience, certifications |
| D2 | Information Security Compliance | 1 and 2 | Bachelor in Accounting, IIA Certificate, CISA, CRISC, Forensics Examiner, vendor-specific trainings |
| D3 | Chief Information Security Officer (CISO) | Executive Management | No academic degree, law enforcement and cyber security experience |
| E1 | IT Auditor | 3 | Bachelor of Computer Science, CISA, ISO |
| E2 | Board's Risk Committee Chairman | Board | Master of Physics, Cyber-security governance training for Boards |
| E3 | CISO | 2 | Bachelor of Computer Science, CISM, CISSA, |
| E4 | Chief Risk Officer | Executive Management | Bachelor of Business and Economics |
| E5 | IT Security Manager | 1 | Bachelor of Electrical Engineering, various certifications, ISO, ISACA, vendor specific |

## Appendix B: Data structure for coding

| Codes (First order concepts) | Second order concepts | Aggregate dimensions |
|---|---|---|
| Incident detection and response | 1st line | Governance structure |
| Vulnerability management | | |
| Vendor management | | |
| Penetration testing | | |
| Selection and implementation of security controls | | |
| Development of operations | | |
| Security architecture | | |
| System automation | | |
| Testing of security products | | |
| Process development around specific topics | | |
| Developing policies and strategies for operations | 2nd line | |
| Cyber and information security compliance functions | | |
| Monitoring of cyber security controls | | |
| Analysing organizational degree of exposure | | |
| Important defensive decision | | |
| Ensuring cyber-risk management integration with ERM | | |
| Developing business continuity plans and disaster planning | | |
| Developing key risk indicators and reporting | | |
| Benchmarking performance | 2nd and 3rd line | |
| Risk assessment | | |
| Managing external assurance provider | | |
| Assurance of CS risk management effectiveness and its alignment with ERM | 3rd line | |
| Allocating resources to CS risk management | Executive management | |
| Developing/endorsing ERM strategies, policies, metrics | | |
| Controlling CS risk management performance | | |
| Overseeing CS risk management | Board of Directors | |
| Providing tone from the top | | |
| Evaluating performance of senior management | | |
| Providing feedback on KPIs | | |
| Separate risk assessment for different purposes | 2nd and 3rd line | Governance relational mechanisms |
| Blended tasks of the first and the second line | 1st and 2nd line | |
| Overdependence on CIO | 4th line | |
| Lack of understanding of the internal auditor's role | 1st, 2nd, 4th and 5th line | |
| Informal close relationships of formally separated roles | 1st, 2nd and (less often) 3rd line | |
| Services such as SOC, patches, intelligence | External providers | Mimetic forces |
| Benchmarking | | |
| Evaluating maturity of CS risk management | | |
| Introducing line role segregation | | |
| A board member on multiple board positions | Professionals of an organization | |
| Professionals' circulation across various industries and organizations | | |
| Professionals sharing openly practices with peers | | |
| Cooperation with industry associations dealing with CS risk management | Industry associations | |
| Cyber related, computer science, IT, information systems, risk management | Academic background | Normative forces |
| CISO, CISM, CIMA, CISSO, certified internal auditor, and others | Professional certifications | |
| Experience on various positions of risk management, information systems and CS | Development through experience | |
| Prudential regulation | CS and privacy regulation | Coercive forces |
| CS regulation | | |
| PCI, PII, audit requirements | | |
| Mandating CS frameworks | Owner's requirements | |
| Performing audits | | |
| Incorporating a certain organization within the parent company organizational structure | | |
| Size | | Efficiency/effectiveness motives |
| Complexity | | |
| Cyber-risk exposure (environmental uncertainty) | | |
| Competition | | |
| Organizational structure | | |

## Appendix C. Supplementary data

Supplementary data to this article can be found online at https://doi.org/10.1016/j.accinf.2023.100642.

## References


ACCA, and CAANZ, 2019. Cyber and the CFO. https://www.charteredaccountantsanz.com/-/media/a82de353ba15474ead28028e53b5b416.ashx.

Aghion, P., Tirole, J., 1997. Formal and real authority in organizations. J. Polit. Econ. 105 (1), 1–29.

AICPA, 2017. Reporting on an entity's cybersecurity risk management program and controls. https://www.aicpa.org/cpe-learning/publication/reporting-on-an-entitys-cybersecurity-risk-management-program-and-controls-attestation-guide-OPL.

Ali, M.I., Kaur, S., Khamparia, A., Gupta, D., Kumar, S., Khanna, A., Al-Turjman, F., 2020. Security challenges and cyber forensic ecosystem in IoT Driven BYOD Environment. IEEE Access 8, 172770–172782.

Australian Institute of Company Directors (AICD) and Cyber security cooperative research centre, 2022. Cyber Security Governance Principles. https://www.aicd.com.au/risk-management/framework/cyber-security/cyber-security-governance-principles.html.

Australian Institute of Company Directors, & Cyber Security Cooperative Research Centre, 2022. Cyber Security Governance Principles https://www.aicd.com.au/content/dam/aicd/pdf/tools-resources/director-tools/board/cyber-security-governance-principles-web3.pdf.

Barton, K.A., Tejay, G., Lane, M., Terrell, S., 2016. Information system security commitment: A study of external influences on senior management. Comput. Secur. 59, 9–25.

Basel Committee on Banking Supervision, 2011. Principles for Sound Management of Operational Risk. https://www.bis.org/publ/bcbs195.htm.

Basel Committee on Banking Supervision, 2021. Principles for Sound Management of Operational Risk. https://www.bis.org/publ/bcbs195.htm.

Benaroch, M., Chernobai, A., 2017. Operational IT failures, IT value destruction, and board-level IT governance changes. MIS Q. 41 (3), 729–762. https://doi.org/10.25300/MISQ/2017/41.3.04.

Burdon, W.M., Sorour, M.K., 2020. Institutional Theory and evolution of 'a legitimate' compliance culture: The case of the UK financial service sector. J. Bus. Ethics 162 (1), 47–80. https://doi.org/10.1007/s10551-018-3981-4.

Coase, R.H., 1937. The nature of the firm. Economica 4 (16), 386–405.

COBIT, 2019. An ISACA Framework. Available at https://www.isaca.org/resources/cobit.

Committee of Sponsoring Organizations of the Tredway Commission (COSO), 2004. Enterprise Risk Management—Integrated Framework. COSO, Washington, DC.

Committee of Sponsoring Organizations of the Tredway Commission (COSO), 2013. Internal Control—Integrated Framework. COSO, Washington, DC.

Committee of Sponsoring Organizations of the Tredway Commission (COSO), 2017. Enterprise Risk Management: Integrating with Strategy and Performance. COSO, Washington, DC.

Constantino, T.E., 2008. The SAGE Encyclopedia of Qualitative Research Methods. SAGE Publications Inc, Thousand Oaks Thousand Oaks, California.

De Haes, S., Van Grembergen, W., 2009. An exploratory study into IT governance implementations and its impact on business/IT alignment. Inf. Syst. Manag. 26 (2), 123–137. https://doi.org/10.1080/10580530902794786.

Deloitte, 2015. COSO in the cyber age. https://www.coso.org/documents/COSO%20in%20the%20Cyber%20Age_FULL_r11.pdf.

DiMaggio, P.J., Powell, W.W., 1983. The iron cage revisited: Institutional isomorphism and collective rationality in organizational fields. Am. Sociol. Rev. 48 (2), 147–160.

Dzuranin, A.C., Mălăescu, I., 2016. The current state and future direction of IT audit: Challenges and opportunities. J. Inform. Syst. 30 (1), 7–20. https://doi.org/10.2308/isys-51315.

Eulerich, M., 2021. The new three lines model for structuring corporate governance – A critical discussion of similarities and differences. Corp. Ownersh. Control. 18 (2), 180–187. https://doi.org/10.22495/cocv18i2art15.

European Banking Authority (EBA), 2019. *Guidelines on information and communication technology (ICT) and security risk management.* https://www.eba.europa.eu/sites/default/ documents/files/document_library/Publications/Guidelines/2020/GLs%20on%20ICT%20and%20security% 20risk%20management/872936/Final%20draft%20Guidelines%20on%20ICT%20and%20security%20risk%20management.pdf.

EY, and Institute of Internal Auditors, 2021. The risky six. Key questions to expose gaps in board understanding of organizational cyber resiliency. https://global.theiia.org/knowledge/Public%20Documents/EY-The-Risky-Six-Board-Disconnections.pdf.

Feng, C., Wang, T., 2018. Does CIO risk appetite matter? Evidence from information security breach incidents. Int. J. Account. Inf. Syst. 32 (1), 59–75.

Freeman, T., Peck, E., 2007. Performing governance: A partnership board dramaturgy. Public Adm. 85 (4), 907–929.

Gale, M., Bongiovanni, I., Slapničar, S., 2022. Governing cybersecurity from the boardroom: challenges, drivers, and ways ahead. Comput. Secur. 121, 102840 https://doi.org/10.1016/j.cose.2022.102840.

Gilligan, M., Herrygers, S., Rau, K., 2019. Managing cyber risk in a digital age. https://www.coso.org/Documents/COSO-Deloitte-Managing-Cyber-Risk-in-a-DigitalAge.pdf.

Gioia, D.A., Corley, K.G., Hamilton, A.L., 2013. Seeking Qualitative Rigor in Inductive Research. Organ. Res. Methods 16, 15–31.

Gordon, L.A., Loeb, M.P., Tseng, C.Y., 2009. Enterprise risk management and firm performance: A contingency perspective. J. Account. Public Policy 28 (4), 301–327.

Granovetter, M., 1985. Economic Action and Social Structure: The Problem of Embeddedness. Am. J. Sociol. 91, 481–510.

Haislip, J., Masli, A., Richardson, V., Sanchez, J.M., 2016. Repairing organizational legitimacy following information technology (IT) material weaknesses: Executive turnover, IT expertise, and IT system upgrades. J. Inf. Syst. 30 (1), 41–70.

Haislip, J., Karim, K., Lin, K.J., Pinsker, R., 2020. The influences of CEO IT expertise and board-level technology committees on Form 8-K disclosure timeliness. J. Inf. Syst. 34 (2), 167–185.

Haislip, J., Karim, K., Lin, K.J., Pinsker, R., 2021. The impact of executives' IT expertise on reported data security breaches. Inform. Syst. Res. 32 (2), 318–334.

Harrast, S.A., Swaney, A.M., 2019. What is the role of the board-level technology committee? J. Corporate Account. Finance 30 (4), 43–47. https://doi-org.ezproxy.library.uq.edu.au/10.1002/jcaf.22414.

Hartmann, C.C., Carmenate, J., 2021. Academic research on the role of corporate governance and IT expertise in addressing cyber security breaches: Implications for practice, policy, and research. Curr. Issues Auditing 15 (2), A9–A23. https://doi.org/10.2308/CIIA-2020-034.

Héroux, S., Fortin, A., 2013. The internal audit function in information technology governance: A holistic perspective. J. Inform. Syst. 27 (1), 189–217. https://doi.org/10.2308/isys-50331.

Higgs, J.L., Pinsker, R.E., Smith, T.J., Young, G.R., 2016. The relationship between board-level technology committees and reported security breaches. J. Inform. Syst. 30 (3), 79–98. https://doi.org/10.2308/isys-51402.

Institute of Internal Auditors, 2013. The three lines of defense in effective risk management and control. https://na.theiia.org/standards-guidance/Public%20Documents/PP%20The%20.Three%20Lines%20of%20Defense%20in%20Effective%20Risk%20Management%20and%20Control.pdf.

Institute of Internal Auditors (IIA), 2020. The IIA's Three lines model. An update of the Three Lines of Defense. https://www.iia.org.au/technical-resources/professionalGuidance/the-iia's-three-linesmodel.

Institute of Internal Auditors (IIA), 2016. *Assessing cybersecurity risk: roles of the three lines of defense.* Retrieved October 20, 2020, from https://global.theiia.org/standards-guidance/Member%20Documents/GTAG-Assessing-Cybersecurity-Risk.pdf.

International Organization for Standardization. International Electrotechnical Commission (ISO/IEC) standards: ISO/IEC 27001:2013, 2013, Information security, cybersecurity and privacy protection – Information security management systems – Requirements, https://www.iso.org/standard/82875.html.

ISACA, 2011. COBIT Process Assessment Model (PAM): Using COBIT 4.1. ISACA, Rolling Meadows, IL.

Islam, M.S., Farah, N., Stafford, T.F., 2018. Factors associated with security/cybersecurity audit by internal audit function. Manag. Audit. J. 33 (4), 377–409. https://doi.org/10.1108/MAJ-07-2017-1595.

International Organization for Standardization / International Electrotechnical Commission (ISO/IEC) standards:ISO/IEC 27002:2013. Information technology – Security techniques – Code of practice for information security controls. https://www.iso.org/standard/54533.html.

International Organization for Standardization. International Electrotechnical Commission (ISO/IEC) standard 27014. 2013. Governance of Information Security. https://www.iso.org/standard/43754.html.

Jeyaraj, A., Zadeh, A., 2020. Institutional isomorphism in organizational cybersecurity: A text analytics approach. J. Organ. Comput. Electron. Commer. 30 (4), 1–20.

Kahyaoglu, S.B., Çaliyurt, K., 2018. Cybersecurity assurance process from the internal audit perspective. Manag. Audit. J. 33 (4), 360–376. https://doi.org/10.1108/MAJ-02-2018-1804.
Kappelman, L., McLean, E., Johnson, V., Torres, R., 2016. The 2015 SIM IT issues and trends study. MIS Q. Exec. 15 (1), 55–83.
Kappelman, L., McLean, E., Johnson, V., Torres, R., Nguyen, Q., Maurer, C., Snyder, M., 2017. The 2016 SIM IT issues and trends study. MIS Q. Exec. 16 (1), 47–80.
KPMG, 2019. Pulse of Fintech H2 2019. https://assets.kpmg/content/dam/kpmg/xx/pdf/2020/02/pulse-of-fintech-h2-2019.pdf.
Lankton, N., Price, J.B., Karim, M., 2021. Cybersecurity Breaches and the Role of Information Technology Governance in Audit Committee Charters. J. Inform. Syst. 35 (1), 101. https://doi.org/10.2308/isys-18-071.
Lawrence, T.B., and Shadnam, M., 2008. Institutional theory. The international encyclopedia of communication.
Lee, I., 2021. Cybersecurity: Risk management framework and investment cost analysis. Bus. Horiz. 64 (5), 659–671.
Leech, T., Hanlon, L., 2016. Three lines of defense versus five lines of assurance. The Handbook of Board Governance: A Comprehensive Guide for Public, Private, and Not-for-Profit Board Members. John Wiley and Sons, New Jersey, pp. 335–355.
Lin, J., Luo, Z., Luo, X., 2020. Understanding the roles of institutional pressures and organizational innovativeness in contextualized transformation toward e-business: Evidence from agricultural firms. Int. J. Inf. Manag. 51, 102025 https://doi.org/10.1016/j.ijinfomgt.2019.10.010.
Lincoln, Y.S., Lynham, S.A., Guba, E.G., 2011. Paradigmatic controversies, contradictions, and emerging confluences, revisited. In: Denzin, N.K., Lincoln, Y.S. (Eds.), The Sage handbook of qualitative research, fourth ed. Sage Publications, Thousand Oaks, CA, pp. 97–128.
Lyons, S. 2011. Corporate oversight and stakeholder lines of defense. The Conference Board Executive Action Repo.
Machold, S., Farquhar, S., 2013. Board task evaluation: A longitudinal field study in the UK. Corp. Gov. 21 (2), 147–164.
Malhotra, Y., 2018. Bridging networks, systems and controls frameworks for cybersecurity curriculums and standards development. J. Operational Risk. 13 (1), 77–99. https://doi.org/10.21314/JOP.2018.201.
Marshall, C., Rossman, G.B., 2011. Designing qualitative research, fifth ed. Sage Publications, Thousand Oaks, CA.
Martin, S. 2014. Cyber Security: 60% of Techies Don't Tell Bosses About Breaches Unless It's 'Serious'. https://www.ibtimes.co.uk/cyber-security-60-techies-dont-tell-bosses-about-breaches-unless-its-serious-1445072.
McKinsey Global Survey. 2018. *A time for boards to act.* https://www.mckinsey.com/business-functions/ strategy-and-corporate-finance/our-insights/a-time-for-boards-to-act.
Nasdaq and Tanium, 2016. The accountability gap: Cybersecurity and building a culture of responsibility, https://www.eidebailly.com/-/media/eide-bailly/website-service/cyber-security/cybersecurity_research_paper_-_the_accountability_gap_-_executive_summary.ashx.
US National Institute of Standards and Technology (NIST) standards; Framework for Improving Critical Infrastructure Cybersecurity. Version 1.1. 2018. https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf.
US National Institute of Standards and Technology (NIST) standards: Special Publication 800-37, Revision 2 (Draft), May 2018.
OECD, 2015. G20/OECD Principles of corporate governance. OECD Publishing, Paris.
Ogbanufe, O., Kim, D.J., Jones, M.C., 2021. Informing cybersecurity strategic commitment through top management perceptions: The role of institutional pressures. Inf. Manag. 58 (7), 103507 https://doi.org/10.1016/j.im.2021.103507.
Parker, L.D., 2008. Boardroom operational and financial control: An insider view. Br. J. Manag. 19 (4), 341–374.
Patton, M.Q., 2014. Qualitative Research And Evaluation Methods: Integrating Theory and Practice. Sage publications.
Peck, E., 1995. The performance of an NHS trust board: Actors' accounts, minutes and observation. Br. J. Manag. 6 (2), 135–156.
Peterson, R.R., 2004. Integration strategies and tactics for information technology governance. In: Van Grembergen, W. (Ed.), Strategies for Information Technology Governance: IGI Global, pp. 37–80.
Power, M., 2009. The risk management of nothing. Acc. Organ. Soc. 34, 849–855. https://doi.org/10.1016/j.aos.2009.06.001.
Protiviti, 2013. Applying the five lines of defense in managing risk. The Bulletin 5, no. 4.
Roberts, P.W., Greenwood, R., 1997. Integrating Transaction Cost and Institutional Theories: Toward a Constrained-Efficiency Framework for Understanding Organizational Design Adoption. AMR 22 (2), 346–373.
Rothrock, R.A., Kaplan, J., Van Der Oord, F., 2018. The board's role in managing cybersecurity risks. MIT Sloan Manag. Rev. 59 (2), 12–15.
Sambamurthy, V., Zmud, R.W., 2000. Research Commentary: The organizing logic for an enterprise's IT activities in the digital era—A prognosis of practice and a call for research. Inf. Syst. Res. 11 (2), 105–114. https://doi.org/10.1287/isre.11.2.105.11780.
Securities and Exchange Commission (SEC). 2011. CF Disclosure Guidance: Topic No. 2 Cybersecurity. https://www.sec.gov/divisions/corpfin/guidance/cfguidance-topic2.htm.
Securities and Exchange Commission (SEC). 2018. Commission Statement and Guidance on Public Company Cybersecurity Disclosures. https://www.sec.gov/rules/interp/2018/33-10459.pdf.
Securities and Exchange Commission (SEC). 2022. Cybersecurity risk management, strategy, governance, and incident disclosure. March. https://www.sec.gov/rules/proposed/2022/33-11038.pdf.
Škiljić, A., 2020. Cybersecurity and remote working: Croatia's (non-)response to increased cyber threats. Int. Cybersecur. Law Rev. 1 (1), 51–61. https://doi.org/10.1365/s43439-020-00014-3.
Slapničar, S., Vuko, T., Čular, M., Drašček, M., 2022. Effectiveness of cybersecurity audit. Int. J. Account. Inform. Syst. 44, 100548 https://doi.org/10.1016/j.accinf.2021.100548.
Smith, T., Tadesse, A.F., Vincent, N.E., 2021. The impact of CIO characteristics on data breaches. Int. J. Account. Inform. Syst. 43, 100532.
Soomro, Z.A., Shah, M.H., Ahmed, J., 2016. Information security management needs more holistic approach: A literature review. Int. J. Inf. Manag. 36 (2), 215–225.
Srinivasan, S., Paine, L., Goyal, N., 2016. Cyber Breach at Target. Harvard Business Publishing Case Study.
Stafford, T., Deitz, G., Li, Y., 2018. The role of internal audit and user training in information security policy compliance. Manag. Audit. J. 33 (4), 410–424. https://doi.org/10.1108/MAJ-07-2017-1596.
Steinbart, P.J., Raschke, R.L., Gal, G., Dilla, W.N., 2018. The influence of a good relationship between the internal audit and information security functions on information security outcomes. Acc. Organ. Soc. 71, 15–29. https://doi.org/10.1016/j.aos.2018.04.005.
Van Grembergen, W., De Haes, S., Guldentops, E., 2004. Structures, processes and relational mechanisms for IT governance. In: Van Grembergen, W. (Ed.), Strategies for Information Technology Governance: IGI Global, pp. 1–36.
Vincent, N.E., Higgs, J.L., Pinsker, R.E., 2019. Board and management-level factors affecting the maturity of IT risk management practices. J. Inform. Syst. 33 (3), 117–135. https://doi.org/10.2308/isys-52229.
Von Solms, B., Von Solms, R., 2018. Cybersecurity and information security – what goes where? Inform. Comput. Secur. 26 (1), 2–9. https://doi.org/10.1108/ics-04-2017-0025.
Vuko, T., Slapničar, S., Čular, M., Drašček, M., 2021. Key drivers of cybersecurity audit effectiveness: the neo-institutional perspective. SSRN Working paper. https://papers.ssrn.com/sol3/papers.cfm?abstract_id=3932177.
Wallace, L., Lin, H., Cefaratti, M.A., 2011. Information security and Sarbanes-Oxley compliance: An exploratory study. J. Inf. Syst. 25 (1), 185–211. https://doi.org/10.2308/jis.2011. 25.1.185.
Walton, S., Wheeler, P.R., Zhang, Y.I., Zhao, X.R., 2021. An integrative review and analysis of cybersecurity research: Current state and future directions. J. Inform. Syst. 35 (1), 155–186. https://doi.org/10.2308/ISYS-19-033.

Wilkin, C.L., Chenhall, R.H., 2020. Information Technology Governance: Reflections on the Past and Future Directions. J. Inf. Syst. 34 (2), 257–292.
Williamson, O., 1975. Markets and hierarchies. Free Press, New York.
Williamson, O.E., 2008. Transaction Cost Economics. Springer, Berlin Heidelberg.
Williamson, O.E., 2007. Transaction Cost Economics: An Introduction. *Economics Discussion Paper No. 2007-3* [Online]. Available: https://ssrn.com/abstract=1691869 or https://dx.doi.org/10.2139/ssrn.1691869.
World Economic Forum, Global Risk Report, 2023, available at https://www.weforum.org/reports/global-risks-report-2023?gclid=Cj0KCQjwn_OlBhDhARIsAG2y6zOzjl3RZjzSbIWBaeP57p4xwxr6YogFh4PjupHlYxdoPzcZNVNy4caAlbwEALw_wcB.
Young, S., 2013. Transaction Cost Economics. In: Idowu, S.O., Capaldi, N., Zu, L., Das Gupta, A. (Eds.), Encyclopedia of Corporate Social Responsibility. Springer, Berlin Heidelberg.